

Denegación de Servicio (DoS)

Seguridad en Sistemas Informáticos — Tema 3.4

José Luis Martínez

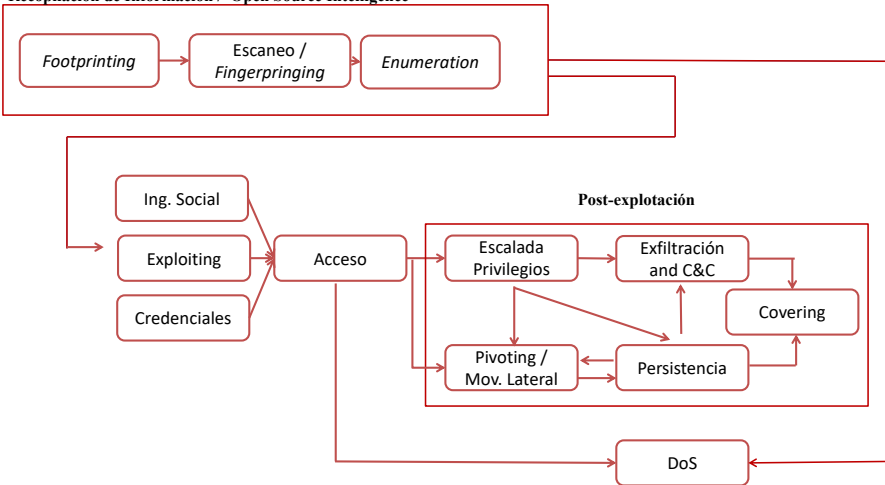
Universidad de Castilla-La Mancha

Curso 2026/27

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Ataques permanentes (phlashing)
- 6 Botnets
- 7 Mitigaciones y contramedidas
- 8 Herramientas y ejercicios

Introducción

Recopilación de Información / Open Source Intelligence



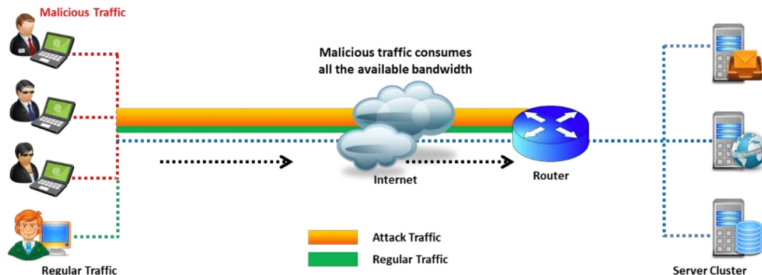
Los dos grandes vectores de ataque

- Tras la fase de recopilación de información, en la que se han identificado los activos de la organización, los dos principales vectores de ataque son:
- **Ataques de acceso** (objetivo principal de un pentesting)
 - Se han visto en profundidad en los temas anteriores: credenciales, ingeniería social y explotación de vulnerabilidades
- **Denegación de servicio (DoS)**
 - A diferencia de los ataques de acceso, que pretenden entrar en un sistema, aquí el objetivo es dejarlo inutilizado para que nadie pueda usarlo
 - No compromete la confidencialidad ni la integridad: ataca directamente a la **disponibilidad**, el tercer pilar de la tríada CIA

Introducción

Qué es un ataque DoS

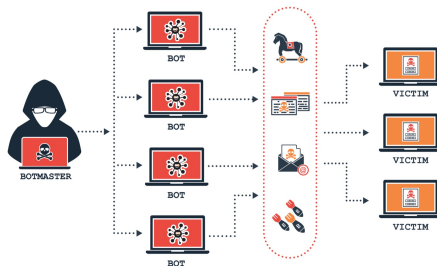
- Los ataques DoS buscan que un recurso de red (un host, un servicio o la propia red de interconexión) reduzca su rendimiento, restrinja el servicio o deje de funcionar para los usuarios legítimos
- Una de las formas más comunes de perpetrarlo es la inundación (*flooding*) de peticiones, hasta saturar la capacidad de respuesta del recurso



Introducción

De DoS a DDoS

- Los ataques DoS distribuidos (DDoS) persiguen el mismo objetivo que los DoS, pero su impacto y su probabilidad de éxito son mucho mayores: parten de una multitud de sistemas comprometidos (*zombies*), normalmente organizados en una *botnet*. Estos bots son gobernados por el atacante mediante un sistema de mando y control (C&C)



El objetivo final de un ataque DoS

- Consumo de recursos: ancho de banda, memoria, disco, CPU o descriptores de fichero
- Agotamiento de tablas de estado en cortafuegos, balanceadores y sistemas operativos
- Ataques físicos de destrucción o alteración de componentes
- Destrucción de ficheros de configuración o de programas del host
- Daño reputacional y económico: el coste de la indisponibilidad suele superar al del incidente técnico

Caso de estudio: caída de WhatsApp, Facebook e Instagram (4 de octubre de 2021)

- No fue un ataque DoS, sino una **autodenegación de servicio**: el efecto sobre los usuarios fue idéntico al de un DDoS masivo (unas 6 h de caída global).
- Cloudflare observó a las 15:40 UTC un pico de cambios de rutas BGP en los sistemas autónomos de Facebook y, a las 15:58 UTC, que Facebook había dejado de anunciar las rutas hacia sus prefijos de DNS: sin ellas, ningún resolutor del mundo podía llegar a sus servidores de nombres.
- Meta confirmó después la causa: durante un mantenimiento rutinario se ejecutó un comando que debía evaluar la capacidad del *backbone* y que tumbó todas las conexiones entre sus centros de datos; un fallo en la herramienta interna de auditoría no impidió que se ejecutase. Al quedar aislados los DNS, éstos retiraron sus anuncios BGP.
- **Lección**: la disponibilidad depende tanto del atacante como de la propia gestión del cambio.
- Referencias:
 - Cloudflare — *Understanding how Facebook disappeared from the Internet*
 - Meta — *Update about the October 4th outage y More details about the October 4 outage*

Introducción

Tipos de ataques de DoS que veremos en el tema

- **Volumétricos** — agotan el ancho de banda (inundación UDP/ICMP, Smurf, amplificación)
- **De consumo** — agotan recursos del host (SYN flood, fragmentación, capa 7)
- **Buffer overflow** — provocan el fallo de la aplicación o del sistema
- **Permanentes o phishing** — dañan el hardware de forma irreversible



Aviso legal y ético

- Lanzar un DoS contra un sistema ajeno **sin autorización expresa y por escrito** es delito en España: el art. 264 bis del Código Penal castiga con prisión de seis meses a tres años a quien obstaculice o interrumpa gravemente el funcionamiento de un sistema informático ajeno.
- Los ejercicios de este tema se realizan **exclusivamente** sobre las máquinas del laboratorio (Metasploitable2, Windows XP/7 en red aislada).
- Nunca se lanzan pruebas contra servicios en producción, redes del campus ni servicios de terceros, aunque sean propios: un DoS puede afectar a toda la infraestructura compartida.
- Referencia: [Código Penal \(texto consolidado, BOE-A-1995-25444\)](#)

- 1 Introducción
- 2 Ataques volumétricos**
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Ataques permanentes (phlashing)
- 6 Botnets
- 7 Mitigaciones y contramedidas
- 8 Herramientas y ejercicios

Ataques volumétricos

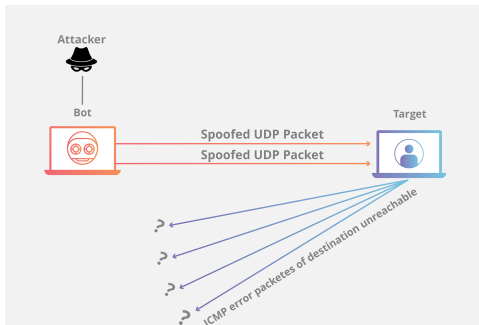
Concepto

- El objetivo de estos ataques es abusar del ancho de banda disponible entre el objetivo (normalmente el servidor) y sus usuarios legítimos.
- Se apoyan en protocolos no orientados a conexión y consisten en inundar la red con ese tipo de paquetes, hasta que el objetivo no es capaz de responder ni a los paquetes del ataque ni a los legítimos.
- Se pueden lanzar también de manera distribuida (DDoS), que es lo habitual hoy en día.
- Se miden en **bits por segundo** (bps): el récord conocido supera los 20 Tbps.
- Tipos que veremos:
 - Inundación UDP
 - Inundación ICMP
 - Smurf
 - Ataques de amplificación y reflexión

Ataques volumétricos

Inundación UDP

- El objetivo es enviar un alto ratio de paquetes UDP a varios servidores con la dirección IP de origen falseada (*spoofed*) con la dirección de la víctima.
- Estos servidores actúan como amplificadores, puesto que reenviarán las respuestas a la IP de la víctima, consiguiendo que ésta se sature y deje de funcionar.



Ataques volumétricos

Inundación ICMP

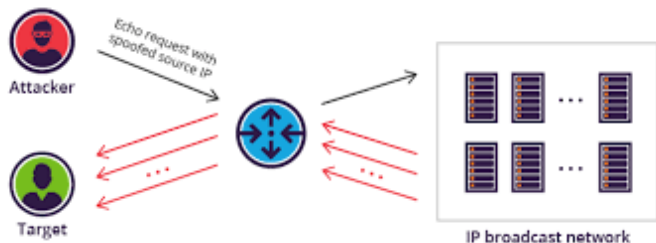
- El objetivo es enviar un alto ratio de paquetes ICMP *echo request* (ping) a la dirección de la víctima, de forma que consuma su ancho de banda respondiendo.
- También se puede hacer rebotado y amplificado (Smurf).



Ataques volumétricos

Smurf

- Es similar al anterior, pero en este caso el atacante falsifica la dirección de origen del paquete ICMP con la IP del objetivo o víctima.
- De esta manera, todas las respuestas le llegan a la víctima y no al atacante.
- Se amplifica enviándolo a la dirección de *broadcast* de la red: todos los equipos del segmento responden a la vez contra la víctima.



Ataques volumétricos

Amplificación y reflexión: factores conocidos

- Combinan *IP spoofing* con servicios UDP que devuelven respuestas mucho mayores que la petición original.

Servicio	Puerto	Factor de amplificación
DNS (petición ANY a resolutor abierto)	53/UDP	28–54×
NTP (comando monlist , CVE-2013-5211)	123/UDP	556×
SNMPv2 (GetBulk a community public)	161/UDP	650×
SSDP (UPnP en dispositivos domésticos)	1900/UDP	30×
CharGEN (servicio <i>legacy</i>)	19/UDP	358×
Memcached (mayor amplificación conocida)	11211/UDP	51.000×

Fuentes: [CISA TA14-017A](#) y [Cloudflare — Memcrashed](#).

Ataques volumétricos

Cómo funciona la amplificación (DNS como ejemplo)

1. El atacante falsifica la IP de origen y pone la IP de la víctima.
2. Envía una petición DNS de tipo `ANY` a un resolutor abierto (petición de pocos bytes).
3. El resolutor responde con paquetes muy grandes dirigidos a la IP de la víctima.
4. Con poco ancho de banda del atacante se genera tráfico masivo sobre la víctima, y además el origen real queda oculto (*reflexión*).

Detección y mitigación

- BCP38 / uRPF: filtrado de *IP spoofing* en origen, responsabilidad de los operadores ([RFC 2827](#)).
- Cerrar los resolutores DNS abiertos y deshabilitar `monlist` en NTP.
- *Rate limiting* de respuestas DNS (RRL) en el resolutor.

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo**
- 4 Buffer overflow
- 5 Ataques permanentes (phlashing)
- 6 Botnets
- 7 Mitigaciones y contramedidas
- 8 Herramientas y ejercicios

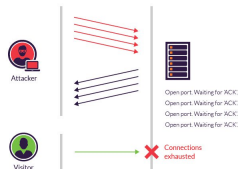
Concepto

- Estos ataques DoS o DDoS se basan en el consumo desmesurado de los recursos de la máquina (memoria, CPU, tablas de conexiones, etc.), derivados del uso de las conexiones del protocolo TCP o de la propia lógica de la aplicación.
- A diferencia de los volumétricos, no necesitan mucho ancho de banda: bastan pocos paquetes bien elegidos.
- Tipos que veremos:
 - Inundación SYN
 - Fragmentación
 - Ataques de capa de aplicación (capa 7)

Ataques de consumo

Inundación SYN

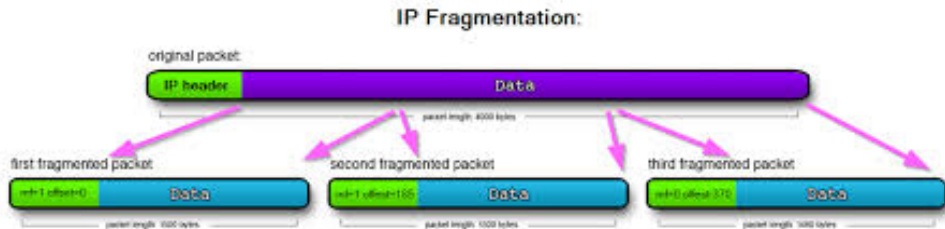
- El atacante envía una gran cantidad de solicitudes SYN al servidor objetivo con direcciones IP de origen falsas, creando conexiones TCP incompletas que consumen los recursos de red de la máquina.
- Se abusa del *three-way handshake* de TCP: el atacante envía un SYN falso; el servidor responde con SYN/ACK y reserva recursos; el cliente nunca envía el ACK final y deja al servidor esperando.
- El host víctima lleva un seguimiento de las conexiones parcialmente abiertas en una cola de escucha, mientras aguarda los ACK que nunca llegan.
- Cuando la cola se llena, el sistema no puede aceptar nuevas conexiones hasta que expiran las anteriores por *timeout*.
- Mitigación de referencia: [RFC 4987 — TCP SYN Flooding Attacks and Common Mitigations](#).



Ataques de consumo

Fragmentación

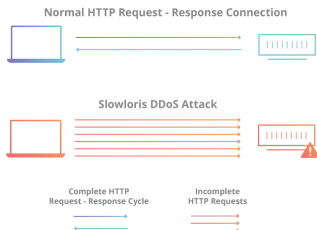
- El atacante intenta agotar la memoria de la víctima fragmentando un paquete muy grande en muchos más pequeños, de forma que el sistema deba mantenerlos en memoria mientras intenta reensamblar el paquete original.
- Si los fragmentos nunca se completan, los búferes de reensamblado se llenan y el impacto es mucho mayor al incrementar la tasa de envío.



Ataques de consumo

Ataques de capa de aplicación

- Se usan protocolos de capa de aplicación, típicamente HTTP.
- El atacante envía un alto ratio de peticiones **GET** o **POST** contra la víctima para saturar sus recursos y que no atienda peticiones legítimas.
- Se miden en **peticiones por segundo** (rps), no en bps.
- Un ejemplo es *slowloris*: el atacante abre muchas conexiones HTTP sin completarlas, hasta alcanzar el máximo de conexiones concurrentes que soporta la víctima.



Ataques de consumo

Slowloris y variantes de ataques lentos

- **Slowloris** — abre conexiones HTTP y envía cabeceras incompletas muy lentamente, manteniéndolas vivas.
- **Slow POST / RUDY** — anuncia un `Content-Length` enorme y envía el cuerpo del `POST` en bytes sueltos cada pocos segundos.
- **Slow Read** — anuncia una ventana TCP de recepción cercana a cero, de modo que el servidor queda bloqueado intentando entregar la respuesta.
- Todos comparten la misma idea: mucho tiempo de conexión con muy poco ancho de banda, lo que los hace difíciles de distinguir de clientes lentos legítimos.
- Herramienta que cubre los tres vectores: `slowhttpptest`

```
slowhttpptest -c 1000 -H -i 10 -r 200 -t GET -u http://<victima>/ -x 24 -p 3
```

HTTP/2 Rapid Reset — CVE-2023-44487

- Descubierta en agosto de 2023 y publicada en octubre; en su momento, el mayor ataque DDoS de capa 7 de la historia.
- Explota el multiplexado de HTTP/2: el atacante abre un *stream* y lo cancela inmediatamente con `RST_STREAM` sin esperar respuesta, a velocidad extrema.
- El servidor ya ha asignado recursos al *stream* cuando procesa el *reset*, así que el coste es asimétrico: mínimo para el atacante, alto para la víctima.
- Cifras notificadas: Google mitigó un pico de **398 millones de peticiones por segundo**; Cloudflare, 201 millones; AWS, 155 millones. Se logró con una botnet de apenas unos 20.000 nodos.
- Mitigación: parches en los servidores HTTP/2 (nginx, Apache, IIS, Go [net/http](#)) y límites al ratio de *streams* cancelados por conexión.
- Referencias: [Cloudflare — HTTP/2 Rapid Reset](#), [Google Cloud](#) y [NVD CVE-2023-44487](#).

Otras herramientas de capa 7

- **LOIC / HOIC** — *HTTP flood* clásico; no anonimiza al atacante y es fácilmente bloqueable por IP.
- **GoldenEye** — *HTTP flood* con `keep-alive` y cabeceras aleatorias para evadir filtros por firma.
- **PyLoris** — implementación en Python de Slowloris con control fino de la cadencia.
- **Tor's Hammer** — *slow POST* enrutado a través de Tor.

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow**
- 5 Ataques permanentes (phlashing)
- 6 Botnets
- 7 Mitigaciones y contramedidas
- 8 Herramientas y ejercicios

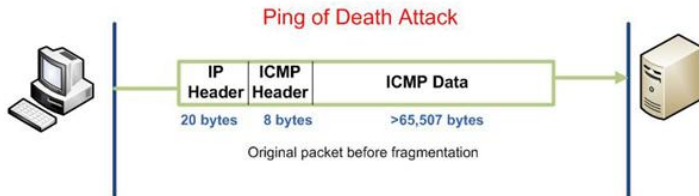
Concepto

- Otra técnica de DoS consiste en conseguir que el sistema objetivo *crashee* debido a una mala programación o gestión de la memoria: los denominados *buffer overflow*.
- Un *buffer overflow* se produce cuando una entrada excede los límites de memoria reservados (de una variable, de un proceso o de la pila) y provoca un comportamiento anómalo.
- Bien construido, permite que el flujo de ejecución salte a donde el atacante quiere, por ejemplo hacia un *payload* que abre una shell (*exploiting*).
- Mal construido — o construido a propósito para ello — desborda hacia una zona de memoria inválida y el programa deja de funcionar: si es una aplicación, cae el servicio; si ocurre en el kernel, cae el sistema completo. En ambos casos, es un DoS.

Buffer overflow

Ping de la muerte

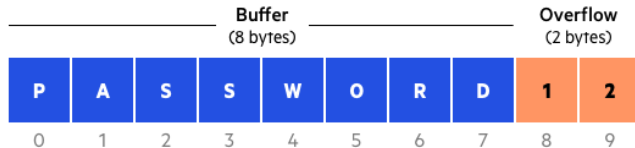
- El atacante intenta bloquear, desestabilizar o congelar el sistema enviando paquetes mal formados o de gran tamaño con un simple comando [ping](#).
- Envía un paquete de 65.538 bytes al destino, excediendo el límite de 65.535 bytes que prescribe el [RFC 791](#) para un datagrama IP.
- El desbordamiento se produce en el proceso de reensamblado del sistema receptor, que no valida el tamaño total de los fragmentos.
- Es un ataque histórico (1996), pero volvió a aparecer en 2013 en IPv6 y en 2020 en Windows (CVE-2020-16898).



Buffer overflow

Crashing de aplicaciones

- Existen bugs que permiten a un usuario exceder los límites previstos por la aplicación y hacer que ésta deje de funcionar.
- Por ejemplo, si un servicio FTP mal programado no valida la entrada de datos del usuario, éste puede exceder los límites de la variable que la recoge. El atacante estaría entonces sobrescribiendo datos de variables contiguas o incluso instrucciones.
- Cuando el programa lee esas posiciones sobrescritas, o ejecuta las instrucciones machacadas, se produce el *crash* de la aplicación: se pierde la lógica del programa y aparece el famoso «pantallazo azul» en Windows o el *crash* en Unix. Es, de nuevo, un DoS.



- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Ataques permanentes (phlashing)**
- 6 Botnets
- 7 Mitigaciones y contramedidas
- 8 Herramientas y ejercicios

Ataques permanentes (phlashing)

Concepto

- Este tipo de ataques se dirige exclusivamente al hardware y causa daños irreversibles; por eso se conocen también como PDoS (*Permanent Denial of Service*).
- Sabotean el hardware del sistema, lo que obliga a la víctima a reemplazar o reinstalar el componente dañado. La vía habitual es la actualización de firmware con una imagen corrupta o maliciosa (de ahí el nombre *phlashing*).
- Otra variante es aquella en la que, a través de un fallo de seguridad o de una conexión directa al dispositivo, se consigue acceso a las interfaces de administración remota y, una vez dentro, se borran ficheros de configuración, se formatea el sistema o se eliminan aplicaciones.
- Caso real: **BrickerBot** (2017) inutilizó miles de dispositivos IoT sobrescribiendo su almacenamiento, como «respuesta» a la botnet Mirai.

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Ataques permanentes (phlashing)
- 6 Botnets**
- 7 Mitigaciones y contramedidas
- 8 Herramientas y ejercicios

Concepto

- Una *botnet* es una red de *zombies* o robots controlados por un *pastor* de bots (*bot herder*).
- Se usan para escaneos masivos, envío de spam, phishing, minado de criptomonedas o campañas de DDoS.
- Los bots son aplicaciones software que ejecutan tareas automatizadas a través de Internet.
- Hay distintos tipos según su canal de mando y control: bots de IRC (los clásicos), bots HTTP/HTTPS, bots P2P (sin servidor central, mucho más resistentes) y bots que abusan de servicios legítimos como redes sociales o DNS.

Procedimiento de infección

- El atacante realiza una exploración para encontrar máquinas vulnerables en una red, investigando direcciones IP al azar del rango objetivo y comprobando si presentan vulnerabilidades.
- Al encontrar una máquina vulnerable, irrumpe en ella e intenta infectarla instalando el código malicioso (*exploit*).
- Una vez comprometida, la máquina descarga el código de la botnet desde un servidor propiedad del atacante. Ese software incorpora un mecanismo de comandos para que el bot y el atacante se comuniquen (C&C).
- El bot recién infectado repite el proceso: así la botnet crece de forma exponencial.

Casos reales y récords

- **Mirai** (2016) — infectó cámaras IP y routers domésticos con credenciales por defecto. Tumbó a KrebsOnSecurity (620 Gbps), a OVH y al proveedor de DNS Dyn, dejando sin servicio a Twitter, Spotify o GitHub en media Norteamérica.
- **Memcached / GitHub** (2018) — 1,35 Tbps por amplificación, sin necesidad de botnet.
- **Google Cloud** (2022) — 46 millones de rps, entonces el mayor ataque de capa 7 conocido.
- **HTTP/2 Rapid Reset** (2023) — 398 millones de rps con apenas 20.000 nodos.
- **Cloudflare** (2025) — ataques hipervolumétricos de más de 20 Tbps y 10.000 millones de paquetes por segundo, atribuidos a la botnet *Aisuru*, heredera de Mirai.
- Referencias: [KrebsOnSecurity](#), [Cloudflare](#) — *Inside Mirai* y [Cloudflare DDoS Threat Report 2025 Q3](#).

Google neutraliza el mayor ataque DDoS
HTTPS registrado hasta la fecha

El ataque DDoS más voluminoso jamás registrado

Un cliente de Google Cloud Armor sufrió un ataque de denegación de servicio distribuido (DDoS) a
resulta del protocolo HTTP/2 que alcanzó los 400 millones de peticiones por segundo, lo que lo
convirtió en el mayor registrado de su tipo.



DoS con anonimato

- El anonimato lo aporta la red Tor (*dark web*)... aunque no hay nada seguro: la propia red Tor tiene vulnerabilidades y los nodos pueden estar mal configurados por sus operadores.
- La idea consiste en lanzar las peticiones masivas a través de Tor para ocultar el origen real del ataque.
- El precio a pagar es el ancho de banda: Tor es lento, así que sólo resulta práctico para ataques de capa 7 de bajo volumen (los ataques lentos vistos antes), nunca para volumétricos.
- Herramientas: [Tor's Hammer](#) (*slow POST* sobre Tor), o cualquier herramienta encapsulada con [torsocks](#).

```
torsocks python3 torshammer.py -t <victima> -r 256
```

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Ataques permanentes (phlashing)
- 6 Botnets
- 7 Mitigaciones y contramedidas**
- 8 Herramientas y ejercicios

Mitigaciones y contramedidas

En el servidor o host

- **SYN cookies** — el servidor responde al SYN con una cookie criptográfica y no reserva recursos hasta recibir el ACK legítimo.
- **Rate limiting** — limitar conexiones por IP y segundo en el cortafuegos o en el kernel.
- **Timeouts agresivos** — reducir el tiempo de espera de las conexiones semiabiertas y de las peticiones incompletas.
- **Deshabilitar servicios UDP amplificadores** — `monlist` en NTP, CharGEN, SNMP v1/v2.
- **Limitar recursos por cliente** — en el servidor web, módulos como `mod_reqtimeout` o `mod_qos` en Apache.

```
sysctl -w net.ipv4.tcp_syncookies=1  
sysctl -w net.ipv4.tcp_max_syn_backlog=4096
```

Mitigaciones y contramedidas

En la red y en el operador

- **BCP38 / uRPF** — filtrado de origen: bloquea los paquetes con IP falseada antes de que salgan de la red del operador ([RFC 2827](#)).
- **BGP blackholing / RTBH** — anunciar al *upstream*, mediante comunidades BGP, que descarte todo el tráfico dirigido a la IP atacada. Sacrifica a la víctima para salvar la red.
- **Anycast** — distribuir el tráfico malicioso entre múltiples PoPs globales, de modo que ningún punto reciba el ataque completo.

Servicios especializados anti-DDoS

- **Scrubbing centers** — centros que limpian el tráfico antes de reenviar sólo el legítimo al origen.
- **CDN + WAF** — Cloudflare, Akamai, AWS Shield, Azure DDoS Protection. Así mitiga Cloudflare: absorbe el tráfico en unos 300 PoPs antes de que llegue al origen.

Detección y monitorización

- Análisis de flujos **NetFlow** / **IPFIX** para detectar volúmenes anómalos por origen, destino o protocolo.
- Umbrales de **pps** (paquetes por segundo) y **rps**: alerta cuando se supera la línea base habitual del servicio.
- **SIEM** con correlación de eventos de red e IDS: [Snort](#), [Suricata](#) o [Zeek](#).
- Plan de respuesta previo: contactos del operador, procedimiento de activación del *scrubbing* y criterios para aplicar *blackholing*.
- Ejercicio recomendado: definir la línea base **antes** del incidente; sin ella, no se distingue un DDoS de un pico de éxito.

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Ataques permanentes (phlashing)
- 6 Botnets
- 7 Mitigaciones y contramedidas
- 8 Herramientas y ejercicios**

Herramientas

Ataque DoS de tipo flooding: hping3

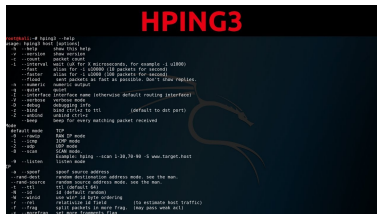
- **hping3** permite construir paquetes TCP/UDP/ICMP a medida y enviarlos a alta velocidad.

```
hping3 -c 15000 -d 120 -S -w 64 -p 80 -flood -rand-source <IP>
```

```
hping3 -S -p 135 -flood <IP>
```

```
hping3 -udp -flood -spooof <IP_falsa> <IP_victima>
```

- **slowloris** — implementación en Python del ataque lento de capa 7.



Metasploit y Nmap NSE

■ Módulos auxiliares de Metasploit:

```
auxiliary/dos/tcp/synflood
```

```
auxiliary/dos/http/slowloris
```

```
auxiliary/dos/windows/rdp/ms12_020_maxchannelids
```

■ Scripts NSE de Nmap:

```
nmap -script http-slowloris -max-parallelism 400 <target>
```

```
nmap -script smb-flood -p445 <host>
```

Yersinia: DoS contra protocolos de nivel 2

- **Yersinia** ataca protocolos de la capa de enlace (STP, CDP, DHCP, DTP, HSRP...), muy eficaces dentro de una LAN.

```
sudo yersinia dhcp -attack 1    (agotamiento del pool DHCP)
```

```
sudo yersinia stp -attack 2    (convertirse en root bridge)
```

```
sudo yersinia cdp -attack 1    (inundación de vecinos CDP)
```

- Contramedidas en el switch: **DHCP snooping**, **BPDU guard** y **port security**.

Ataques DoS de tipo buffer overflow

- Metasploit: `search dos` localiza múltiples exploits DoS para distintas aplicaciones.
- Exploit-DB:
 - Exploits DoS para sistemas Windows con módulo en Metasploit
 - Exploits DoS para aplicaciones Linux

Ejercicio

DoS volumétrico



- Utiliza `hping3` para hacer un ataque DoS al servidor web alojado en la máquina Metasploitable2.
- Utiliza Metasploit y su módulo `synflood` para hacer un DoS al servicio SSH de la misma máquina.
- Nota: si te atreves, puedes probar a hacer un DoS al router de tu casa (y sólo al tuyo).

Ejercicio

DoS buffer overflow



- A partir de esta máquina [Windows XP](#), en la que he instalado un servidor FTP vulnerable:
- Realiza un *fingerprinting* del servicio FTP.
- Localiza un exploit en Metasploit para hacer un ataque DoS a dicho servicio.
- Realiza el ataque y comprueba cómo la aplicación crashea.

Ejercicio

DoS buffer overflow: Mikrotik



- Utiliza la aplicación Mikrotik disponible en [Exploit-DB 24968](#).
- Utiliza Metasploit para realizar un ataque de tipo DoS.

Ejercicio

DoS a Windows RDP



- A partir de las máquinas Windows 7 y/o Windows XP del laboratorio, determina si son vulnerables a [MS12-020](#) (puerto 3389/TCP).
- Módulo auxiliar a utilizar:

```
auxiliary/dos/windows/rdp/ms12_020_maxchannelids
```

Exploits manuales «in the wild» de DoS para practicar

- VX Search Enterprise 10.1.12, vulnerable a DoS en Windows 7: [exploit 43451](#)
- OneHTTPD 0.7, con exploit manual en Python 2: [exploit 27553](#)
- HD Tune Pro 5.70: [exploit 45298](#)
- Para cada uno: identifica el vector, adapta el exploit a tu laboratorio y documenta el comportamiento del servicio antes y después del ataque.

Estándares y documentación técnica

- RFC 4987 — *TCP SYN Flooding Attacks and Common Mitigations*
- RFC 2827 (BCP38) — *Network Ingress Filtering*
- CISA TA14-017A — *UDP-Based Amplification Attacks*
- NVD CVE-2023-44487 — HTTP/2 Rapid Reset

Análisis de incidentes reales

- Cloudflare — caída de Facebook (2021) y [postmortem de Meta](#)
- Cloudflare — análisis retrospectivo de Mirai
- Cloudflare DDoS Threat Report — informe trimestral de tendencias
- INCIBE-CERT — blog y avisos en español

¡Gracias!

Seguridad en Sistemas Informáticos — Tema 3.4